

WORKER DIGITAL RIGHTS AUDIT

Informe de Auditoría de Derechos Digitales del Trabajador

Herramienta de auditoría técnica independiente — uso defensivo

Fecha de generación	2026-05-31 07:52:27
Riesgo máximo detectado	ROJO — Capacidad altamente invasiva
Total de hallazgos	60
Hash de sesión (integridad)	9a03f93ab018ae03e53183c3f8ed6dc4...

AVISO: Este informe ha sido generado de forma automática mediante análisis de configuración local del sistema. No intercepta tráfico de red, no escala privilegios, no exfiltra datos ni compromete la infraestructura. Los hallazgos describen *capacidades técnicas detectadas*, no confirman uso indebido. Para valoración jurídica, consulte con asesor laboral especializado.

Resumen de Hallazgos

Skill	Hallazgo	Categoría	Riesgo
mdm audit	MDM / Gestión corporativa del dispositivo	Corporate Control	YELLOW
mdm audit	Políticas MDM/GPO de restricción USB (1 reglas, 0 bloqueos activos)	mdm usb restrictions	YELLOW
mdm audit	Políticas de control de instalación de software (12 reglas)	mdm software install policy	YELLOW
mdm audit	Políticas DLP de dispositivo via MDM (10 reglas)	mdm dlp device policy	YELLOW
surveillance audit	CrowdStrike Falcon detectado	edr xdr	YELLOW
surveillance audit	Microsoft Defender for Endpoint detectado	edr xdr	YELLOW
surveillance audit	Certificado raíz de inspección SSL/TLS detectado	ssl inspection	ORANGE
surveillance audit	Extensiones de navegador forzadas por política corporativa	browser inspection	ORANGE
persistence audit	Servicios con características de monitorización (25 detectados)	persistence services	YELLOW
persistence audit	Drivers con características de monitorización (28)	persistence drivers	YELLOW
persistence audit	Vectores de DLL hijacking detectados (15)	persistence dll hijacking	YELLOW
persistence audit	Certificados raíz no estándar en el almacén del sistema (30, posible S	persistence untrusted certs	ORANGE
network monitor	Conexiones externas activas (26 establecidas)	network external	YELLOW
network monitor	DNS corporativo interno detectado	network dns	YELLOW
activity monitor	Procesos con alto consumo de recursos (15 detectados)	activity resources	YELLOW
activity monitor	Procesos con múltiples conexiones salientes (4)	activity data senders	YELLOW
privacy audit	Posible acceso al portapapeles detectado (1 apps)	privacy clipboard	ORANGE
ai telemetry audit	Nivel de telemetría de Windows: Completa (por defecto, sin política re	telemetry windows level	RED
ai telemetry audit	Servicios de telemetría activos (3 en ejecución)	telemetry services	RED
ai telemetry audit	Telemetría de Microsoft Office/365	telemetry office	ORANGE
ai telemetry audit	Experiencias conectadas de Office activas — contenido enviado a Micros	ai connected experiences	ORANGE
cloud sync audit	Microsoft OneDrive activo — sincronización en segundo plano	cloud sync service	ORANGE
cloud sync audit	SharePoint / OneDrive Empresarial activo — sincronización en segundo p	cloud sync service	ORANGE
cloud sync audit	Carpetas del sistema redirigidas a nube (7 carpetas)	cloud sync folder redirect	RED

Skill	Hallazgo	Categoría	Riesgo
cloud sync audit	Políticas corporativas de OneDrive activas — KFM forzado por GPO	cloud sync policy	ORANGE
browser audit	Extensiones forzadas por política corporativa (1 extensiones)	browser forced extensions	ORANGE
browser audit	Políticas corporativas en Google Chrome (3 activas)	browser policies	ORANGE
browser audit	Políticas corporativas en Microsoft Edge (4 activas)	browser policies	ORANGE
browser audit	Políticas corporativas en Mozilla Firefox (1 activas)	browser policies	ORANGE
hardening audit	Configuraciones de seguridad ausentes (8 de 14)	hardening missing	RED
hardening audit	AUSENTE: BitLocker — Cifrado de disco	hardening encryption	RED
hardening audit	AUSENTE: Secure Boot — Arranque seguro	hardening boot	ORANGE
hardening audit	AUSENTE: Windows Firewall — Cortafuegos	hardening network	ORANGE
hardening audit	AUSENTE: Windows Defender — Protección en tiempo real	hardening antimalware	ORANGE
identity audit	Cuentas locales detectadas (8 total, 2 sospechosas)	identity local accounts	ORANGE
identity audit	Grupo Administradores: 4 miembros	identity admin group	ORANGE
identity audit	Acceso remoto habilitado	identity remote access	ORANGE
identity audit	Credenciales almacenadas en Windows Credential Manager (44)	identity stored credentials	ORANGE
identity audit	Servicios con cuentas de usuario específicas (8)	identity service accounts	YELLOW
identity audit	Procesos de monitorización con privilegios de sistema (1)	identity privileged monitoring	YELLOW
identity audit	Perfiles de cuentas — 2 con alertas (1 alto riesgo)	identity account profiles	ORANGE
identity audit	Cuenta: EMEAL-IT — 2 alertas	identity suspicious account	RED
git identity audit	.gitconfig global modificado hace menos de 7 días	gitconfig recently modified	YELLOW
git identity audit	Configuración SSH personalizada detectada	ssh config present	GREEN
usb audit	Historial completo de dispositivos USB (6 registros)	usb full history	GREEN
usb audit	Dispositivos USB actualmente conectados (8)	usb connected now	GREEN
usb audit	Políticas de restricción de USB/almacenamiento extraíble (1)	usb dlp policies	YELLOW
email audit	Add-ins de Outlook detectados (6, 0 con indicadores de monitorización)	email outlook addins	YELLOW
email audit	Perfiles de Outlook configurados (1)	email outlook profiles	GREEN
third party apps audit	Apps corporativas con telemetría detectadas (3)	third party apps installed	YELLOW
third party apps audit	Políticas corporativas GPO de apps de terceros (2 apps)	third party apps policies	ORANGE

Skill	Hallazgo	Categoría	Riesgo
third party apps audit	Extensiones de VSCode instaladas (15, 0 con indicadores de telemetría)	vscode extensions	GREEN
user behavior audit	Capacidades de logging de actividad activas (1)	behavior logging capabilities	YELLOW
data exfiltration audit	Software DLP del empleador activo (5 instalado, 0 en ejecución)	exfiltration dlp monitoring	ORANGE
data exfiltration audit	Archivos grandes en Downloads/Desktop (2 > 50 MB)	exfiltration large files	ORANGE
data exfiltration audit	Herramientas CLI de nube instaladas (1, 0 con credenciales)	exfiltration cloud cli	YELLOW
incident response	Playbook de respuesta al trabajador — Urgencia: INMEDIATA (< 24 horas)	incident response playbook	RED
incident response	Checklist de preservación de evidencia digital	incident response evidence	YELLOW
incident response	Guía de derechos y canales de denuncia (31 hallazgos de riesgo alto/mu)	incident response rights	YELLOW
event viewer audit	Event Viewer audit parcial: logs no accesibles (2/4)	event viewer collection status	YELLOW

Detalle de Hallazgos

#1 — MDM / Gestión corporativa del dispositivo

YELLOW

Skill: mdm_audit | Categoría: Corporate Control | Timestamp: 2026-05-31T07:45:44.207673

Qué es:

MDM (Mobile Device Management) es software que permite a las empresas gestionar dispositivos corporativos: aplicar políticas de seguridad, instalar apps, configurar VPN y, en caso extremo, borrar el dispositivo.

Qué NO implica:

MDM por sí solo no implica monitorización de actividad, lectura de mensajes personales ni vigilancia en tiempo real. Gestiona el dispositivo, no espía al usuario.

Riesgo técnico:

MDM permite a la organización instalar software, aplicar políticas, borrar el dispositivo remotamente y restringir aplicaciones.

Riesgo jurídico:

La gestión MDM en dispositivos corporativos es generalmente legítima bajo el ET y LOPDGDD si está informada al trabajador.

#2 — Políticas MDM/GPO de restricción USB (1 reglas, 0 bloqueos activos)

YELLOW

Skill: mdm_audit | Categoría: mdm_usb_restrictions | Timestamp: 2026-05-31T07:45:44.226237

Qué es:

Políticas del sistema operativo o MDM que controlan el acceso a dispositivos de almacenamiento USB extraíble.

Qué NO implica:

No toda restricción USB es ilegítima. Es una medida de seguridad corporativa estándar.

Riesgo técnico:

Las políticas de USB pueden bloquear dispositivos, registrar intentos de conexión o aplicarse de forma silenciosa. Si registran intentos, la empresa puede saber cuándo y qué dispositivos intentó conectar el trabajador.

Riesgo jurídico:

Las restricciones de USB son medidas DLP legítimas. Si los intentos se registran y analizan, requieren información previa bajo LOPDGDD art. 87.

#3 — Políticas de control de instalación de software (12 reglas)

YELLOW

Skill: mdm_audit | Categoría: mdm_software_install_policy | Timestamp: 2026-05-31T07:45:44.244127

Qué es:

Políticas de administración de Windows que determinan qué software puede instalarse y quién puede hacerlo.

Qué NO implica:

No es vigilancia del trabajador. Es control de la integridad del dispositivo corporativo.

Riesgo técnico:

Estas políticas pueden bloquear la instalación de software no autorizado, deshabilitar el Panel de Control o restringir el acceso a herramientas del sistema.

Riesgo jurídico:

Las restricciones de instalación son una medida de seguridad corporativa estándar. No afectan directamente a los derechos del trabajador salvo que impidan el uso de herramientas laborales.

#4 — Políticas DLP de dispositivo via MDM (10 reglas)

YELLOW

Skill: mdm_audit | Categoría: mdm_dlp_device_policy | Timestamp: 2026-05-31T07:45:44.267392

Qué es:

Herramientas de clasificación y protección de información corporativa que controlan cómo se usan y comparten los documentos.

Qué NO implica:

No es vigilancia del trabajador. Es protección de la información de la empresa frente a fuga de datos.

Riesgo técnico:

Azure Information Protection (AIP) / Microsoft Purview puede clasificar y cifrar documentos automáticamente, registrar accesos y bloquear la transferencia de archivos etiquetados como confidenciales.

Riesgo jurídico:

El DLP de dispositivo que clasifica y controla documentos puede afectar archivos personales si están en el equipo corporativo. Requiere información previa bajo LOPDGDD art. 87.

#5 — CrowdStrike Falcon detectado

YELLOW

Skill: surveillance_audit | Categoría: edr_xdr | Timestamp: 2026-05-31T07:45:44.344447

Qué es:

Agente EDR/XDR detectado. Estos sistemas monitorizan comportamiento del sistema en tiempo real para detectar amenazas.

Qué NO implica:

No implica necesariamente lectura de contenido personal. Es seguridad corporativa estándar en empresas medianas y grandes.

Riesgo técnico:

Monitoriza procesos, red y comportamiento del sistema.

Riesgo jurídico:

Riesgo legal estimado: low-medium. Ver compliance engine para análisis LOPDGDD/RGPD.

#6 — Microsoft Defender for Endpoint detectado

YELLOW

Skill: surveillance_audit | Categoría:edr_xdr | Timestamp: 2026-05-31T07:45:44.372370

Qué es:

Agente EDR/XDR detectado. Estos sistemas monitorizan comportamiento del sistema en tiempo real para detectar amenazas.

Qué NO implica:

No implica necesariamente lectura de contenido personal. Es seguridad corporativa estándar en empresas medianas y grandes.

Riesgo técnico:

Monitoriza procesos, red y comportamiento del sistema.

Riesgo jurídico:

Riesgo legal estimado: low-medium. Ver compliance engine para análisis LOPDGDD/RGPD.

#7 — Certificado raíz de inspección SSL/TLS detectado

ORANGE

Skill: surveillance_audit | Categoría:ssl_inspection | Timestamp: 2026-05-31T07:45:48.396809

Qué es:

Un certificado raíz de inspección SSL permite al proxy corporativo actuar como intermediario en conexiones HTTPS, descifrando el tráfico para inspeccionarlo.

Qué NO implica:

No demuestra que el tráfico se esté leyendo activamente, pero sí que existe la capacidad técnica.

Riesgo técnico:

Con este certificado instalado, un proxy corporativo puede descifrar, analizar y registrar todo el tráfico HTTPS, incluyendo contraseñas y contenido de páginas web.

Riesgo jurídico:

Requiere informar explícitamente al trabajador. Sin información previa puede vulnerar art. 87 LOPDGDD y doctrina Barbulescu II (TEDH).

#8 — Extensiones de navegador forzadas por política corporativa

ORANGE

Skill: surveillance_audit | Categoría:browser_inspection | Timestamp: 2026-05-31T07:45:48.424666

Qué es:

Extensiones instaladas por GPO/política que el usuario no puede desinstalar.

Qué NO implica:

No implica necesariamente espionaje. Muchas son extensiones de seguridad o DLP legítimas.

Riesgo técnico:

Las extensiones forzadas pueden tener acceso completo al contenido de páginas web, historial y formularios.

Riesgo jurídico:

Depende de la funcionalidad de cada extensión. Si capturan contenido web personal, aplica LOPDGDD art. 87.

#9 — Servicios con características de monitorización (25 detectados)

YELLOW

Skill: persistence_audit | Categoría: persistence_services | Timestamp: 2026-05-31T07:45:48.469408

Qué es:

Servicios de Windows que se ejecutan continuamente en segundo plano.

Qué NO implica:

No todo servicio con estas palabras es espionaje. Windows incluye muchos servicios de telemetría propios.

Riesgo técnico:

Los servicios de Windows se ejecutan en segundo plano con privilegios elevados y pueden monitorizar el sistema.

Riesgo jurídico:

Depende de la funcionalidad real. Requiere análisis individual de cada servicio.

#10 — Drivers con características de monitorización (28)

YELLOW

Skill: persistence_audit | Categoría: persistence_drivers | Timestamp: 2026-05-31T07:46:13.153882

Qué es:

Drivers de Windows que operan a nivel de kernel para interceptar o filtrar actividad del sistema.

Qué NO implica:

La mayoría son componentes de seguridad legítimos (antivirus, EDR). No implican espionaje por definición.

Riesgo técnico:

Los drivers de kernel tienen acceso privilegiado a todo el sistema: red, ficheros, procesos, entrada.

Riesgo jurídico:

Depende del fabricante y función. EDR/antivirus usan drivers legítimamente.

#11 — Vectores de DLL hijacking detectados (15)

YELLOW

Skill: persistence_audit | Categoría: persistence_dll_hijacking | Timestamp: 2026-05-31T07:46:15.922019

Qué es:

Vectores técnicos en la configuración del sistema que permiten cargar DLLs alternativas en lugar de las originales, potencialmente interceptando el comportamiento de las apps.

Qué NO implica:

No toda condición de hijacking está siendo explotada. Son debilidades de configuración que aumentan el riesgo.

Riesgo técnico:

El DLL hijacking permite a código malicioso o a software de monitorización interceptar las llamadas a librerías del sistema sin necesidad de modificar el ejecutable original. Es una técnica difícil de detectar por el usuario.

Riesgo jurídico:

Si hay software corporativo que usa DLL hijacking para monitorizar aplicaciones, es especialmente problemático desde el punto de vista legal: opera de forma encubierta y puede interceptar datos de cualquier aplicación.

#12 — Certificados raíz no estándar en el almacén del sistema (30, posible SSL inspection)

ORANGE

Skill: persistence_audit | Categoría: persistence_untrusted_certs | Timestamp: 2026-05-31T07:46:18.931270

Qué es:

Certificados de autoridad de certificación instalados en el almacén de confianza del sistema, emitidos por entidades corporativas o desconocidas en lugar de CAs públicas estándar.

Qué NO implica:

No todo certificado corporativo es para inspección SSL. Las empresas instalan certificados propios para aplicaciones internas, VPN y servicios corporativos.

Riesgo técnico:

Certificados raíz corporativos permiten al empleador realizar inspección SSL (Man-in-the-Middle) del tráfico HTTPS. Con estos certificados, el proxy corporativo puede descifrar y leer toda la comunicación cifrada del navegador.

Riesgo jurídico:

La inspección SSL con certificados raíz corporativos es una práctica que el TEDH (Barbulescu II) exige comunicar previamente al trabajador con detalle sobre su alcance. Sin información puede vulnerar el secreto de las comunicaciones.

#13 — Conexiones externas activas (26 establecidas)

YELLOW

Skill: network_monitor | Categoría: network_external | Timestamp: 2026-05-31T07:46:18.956860

Qué es:

Conexiones TCP activas desde este equipo hacia servidores en Internet.

Qué NO implica:

No implica exfiltración de datos personales. La mayoría son actualizaciones, telemetría de SO y aplicaciones legítimas.

Riesgo técnico:

Las conexiones externas establecidas pueden corresponder a agentes corporativos enviando telemetría, datos de monitorización o actualizaciones.

Riesgo jurídico:

Las conexiones en sí no implican ilegalidad. El riesgo depende del tipo de datos transmitidos.

#14 — DNS corporativo interno detectado

YELLOW

Skill: network_monitor | Categoría: network_dns | Timestamp: 2026-05-31T07:46:27.472823

Qué es:

Servidor DNS interno que traduce nombres de dominio a IPs y puede registrar todas las consultas.

Qué NO implica:

El DNS no ve el contenido de las comunicaciones, solo los nombres de dominio consultados.

Riesgo técnico:

El DNS corporativo registra cada dominio consultado, revelando qué servicios y sitios web usa el equipo.

Riesgo jurídico:

Los logs DNS revelan patrones de uso sin descifrar tráfico. Su retención y análisis está sujeta al RGPD.

#15 — Procesos con alto consumo de recursos (15 detectados)

YELLOW

Skill: activity_monitor | Categoría: activity_resources | Timestamp: 2026-05-31T07:46:50.975835

Qué es:

Procesos que consumen más recursos de lo normal, lo que puede indicar actividad de análisis en segundo plano.

Qué NO implica:

Puede ser actividad legítima: compilaciones, antivirus escaneando, actualizaciones, backups.

Riesgo técnico:

Los procesos con alto consumo pueden estar procesando o transmitiendo grandes volúmenes de datos del sistema.

Riesgo jurídico:

Por sí solo no implica ilegalidad. Requiere identificación del proceso.

#16 — Procesos con múltiples conexiones salientes (4)

YELLOW

Skill: activity_monitor | Categoría: activity_data_senders | Timestamp: 2026-05-31T07:47:18.077736

Qué es:

Procesos que mantienen varias conexiones de red abiertas simultáneamente.

Qué NO implica:

Navegadores y aplicaciones modernas mantienen múltiples conexiones por diseño.

Riesgo técnico:

Múltiples conexiones simultáneas pueden indicar envío de datos a varios servidores en paralelo.

Riesgo jurídico:

Requiere identificación de los procesos y sus destinos para evaluar el riesgo real.

#17 — Posible acceso al portapapeles detectado (1 apps)

ORANGE

Skill: privacy_audit | Categoría: privacy_clipboard | Timestamp: 2026-05-31T07:47:18.122338

Qué es:

Software con acceso al portapapeles del sistema, que puede leer lo que el usuario copia.

Qué NO implica:

Gestores de portapapeles como Ditto o ClipX son herramientas legítimas de productividad.

Riesgo técnico:

El portapapeles puede contener contraseñas, tokens, datos bancarios y comunicaciones privadas copiadas recientemente.

Riesgo jurídico:

El acceso al portapapeles sin consentimiento puede capturar datos especialmente sensibles. Alto riesgo bajo RGPD art. 9 si incluye datos de categoría especial.

#18 — Nivel de telemetría de Windows: Completa (por defecto, sin política restrictiva)

RED

Skill: ai_telemetry_audit | Categoría: telemetry_windows_level | Timestamp: 2026-05-31T07:47:20.665771

Qué es:

Windows envía datos de uso, diagnóstico y en niveles altos contenido de documentos y actividad del usuario a servidores de Microsoft en EEUU.

Qué NO implica:

No todo dato enviado es ilegal. La base legal puede ser interés legítimo o contrato de servicio. El problema es la falta de transparencia y control.

Riesgo técnico:

Nivel Completo (3): Microsoft recopila contenido de documentos, historial de navegación, uso de aplicaciones, búsquedas, voz, tinta digital y diagnósticos detallados del sistema. Nivel Básico (1): hardware, crashes, compatibilidad. Nivel Mejorado (2): uso de apps y rendimiento.

Riesgo jurídico:

La telemetría de nivel completo transfiere datos personales a Microsoft fuera del EEE sin control explícito del trabajador. Requiere análisis bajo RGPD capítulo V (transferencias internacionales) y base legal bajo art. 6 RGPD.

#19 — Servicios de telemetría activos (3 en ejecución)

RED

Skill: ai_telemetry_audit | Categoría: telemetry_services | Timestamp: 2026-05-31T07:47:32.166300

Qué es:

Servicios de Windows que recopilan y transmiten datos de uso, errores y diagnóstico a Microsoft.

Qué NO implica:

No todos los datos son personales en sentido estricto. Muchos son datos técnicos de hardware y estabilidad.

Riesgo técnico:

DiagTrack (Connected User Experiences) es el servicio principal de telemetría. Recopila continuamente datos de actividad y los envía a Microsoft. No se puede desactivar completamente en Windows 11 Home.

Riesgo jurídico:

Los servicios de telemetría operan como tratamiento continuo de datos personales. En equipos corporativos el empleador es corresponsable del tratamiento bajo RGPD art. 26.

#20 — Telemetría de Microsoft Office/365

ORANGE

Skill: ai_telemetry_audit | Categoría: telemetry_office | Timestamp: 2026-05-31T07:47:32.182626

Qué es:

Sistema de telemetría de Microsoft Office que recopila datos de uso y en algunos casos contenido de documentos.

Qué NO implica:

Microsoft afirma que el contenido de documentos no se usa sin consentimiento. Los Terms of Service tienen excepciones amplias.

Riesgo técnico:

Office 365 puede enviar: nombres de archivos, tipos de contenido, funciones usadas, errores, y con servicios conectados activos: fragmentos de texto para traducción, corrección y sugerencias de IA.

Riesgo jurídico:

El envío de contenido de documentos laborales a Microsoft puede incluir datos personales de terceros (clientes, empleados) sin base legal adecuada. Responsabilidad del empleador como responsable del tratamiento.

#21 — Experiencias conectadas de Office activas — contenido enviado a Microsoft

ORANGE

Skill: ai_telemetry_audit | Categoría: ai_connected_experiences | Timestamp: 2026-05-31T07:47:35.023604

Qué es:

Funciones de Microsoft 365 que requieren enviar contenido a servidores de Microsoft para funcionar: traducción, diseño, sugerencias de IA.

Qué NO implica:

No es espionaje directo. Es el modelo de negocio de SaaS: el servicio requiere acceso al contenido para funcionar. El problema es la transparencia y el control del usuario.

Riesgo técnico:

Las experiencias conectadas incluyen: traducción automática de documentos, sugerencias de escritura con IA (Editor), búsqueda inteligente (contenido enviado a Bing), PowerPoint Designer (imágenes y contenido de diapositivas), y análisis de datos en Excel con IA.

Riesgo jurídico:

El contenido de documentos laborales que se envía a Microsoft para procesamiento de IA puede incluir datos personales de clientes o empleados. El empleador debe tener DPA con Microsoft y base legal bajo RGPD art. 6 y 28.

#22 — Microsoft OneDrive activo — sincronización en segundo plano

ORANGE

Skill: cloud_sync_audit | Categoría: cloud_sync_service | Timestamp: 2026-05-31T07:47:35.046833

Qué es:

Microsoft OneDrive sincroniza automáticamente archivos locales hacia servidores en la nube, manteniéndolos accesibles desde cualquier dispositivo.

Qué NO implica:

La sincronización en nube no implica acceso no autorizado por terceros. El riesgo es la transferencia de datos sin control explícito y la accesibilidad desde otros dispositivos.

Riesgo técnico:

Datos sincronizados: Archivos del perfil de usuario, documentos, escritorio. Destino: Microsoft Azure (EEUU/UE según configuración). La sincronización ocurre automáticamente en segundo plano sin intervención del usuario.

Riesgo jurídico:

La sincronización automática puede constituir transferencia internacional de datos personales bajo RGPD cap. V. En equipos corporativos el empleador debe tener DPA con el proveedor de nube y base legal adecuada.

#23 — SharePoint / OneDrive Empresarial activo — sincronización en segundo plano

ORANGE

Skill: cloud_sync_audit | Categoría: cloud_sync_service | Timestamp: 2026-05-31T07:47:35.074990

Qué es:

SharePoint / OneDrive Empresarial sincroniza automáticamente archivos locales hacia servidores en la nube, manteniéndolos accesibles desde cualquier dispositivo.

Qué NO implica:

La sincronización en nube no implica acceso no autorizado por terceros. El riesgo es la transferencia de datos sin control explícito y la accesibilidad desde otros dispositivos.

Riesgo técnico:

Datos sincronizados: Documentos corporativos, librerías de SharePoint. Destino: Microsoft 365 (tenant corporativo). La sincronización ocurre automáticamente en segundo plano sin intervención del usuario.

Riesgo jurídico:

La sincronización automática puede constituir transferencia internacional de datos personales bajo RGPD cap. V. En equipos corporativos el empleador debe tener DPA con el proveedor de nube y base legal adecuada.

#24 — Carpetas del sistema redirigidas a nube (7 carpetas)

RED

Skill: cloud_sync_audit | Categoría: cloud_sync_folder_redirect | Timestamp: 2026-05-31T07:47:35.095639

Qué es:

Redirección de carpetas de Windows hacia OneDrive/SharePoint, convirtiendo el almacenamiento local en almacenamiento corporativo en la nube.

Qué NO implica:

Es una práctica común en entornos corporativos para backup y acceso multi-dispositivo. No implica lectura activa de contenidos, pero sí acceso técnico posible.

Riesgo técnico:

Cada archivo que el trabajador guarda en estas carpetas se sincroniza automáticamente a la nube sin ninguna acción adicional. Incluye: documentos de trabajo, archivos personales, screenshots, descargas guardadas en escritorio.

Riesgo jurídico:

La redirección automática de carpetas del sistema implica que el empleador (a través de Microsoft 365) tiene acceso inmediato a cualquier archivo guardado. Esto puede incluir notas personales, documentos sindicales o comunicaciones privadas. LOPDGDD art. 87 y ET art. 20bis requieren información previa y proporcionalidad.

#25 — Políticas corporativas de OneDrive activas — KFM forzado por GPO

ORANGE

Skill: cloud_sync_audit | Categoría: cloud_sync_policy | Timestamp: 2026-05-31T07:47:35.111582

Qué es:

Configuración GPO que controla cómo OneDrive se comporta en los equipos de la organización.

Qué NO implica:

Las políticas GPO de OneDrive son gestión IT corporativa legítima. El problema es la transparencia hacia el trabajador.

Riesgo técnico:

Las políticas GPO de OneDrive pueden forzar la sincronización de carpetas del sistema sin que el usuario pueda desactivarla. 'KFMBlockOptOut' impide que el trabajador desactive la sincronización de Escritorio y Documentos.

Riesgo jurídico:

Forzar KFM mediante GPO sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El trabajador no puede controlar qué datos se sincronizan a la nube corporativa.

#26 — Extensiones forzadas por política corporativa (1 extensiones)

ORANGE

Skill: browser_audit | Categoría: browser_forced_extensions | Timestamp: 2026-05-31T07:47:35.129284

Qué es:

Extensiones de navegador instaladas por la empresa mediante política GPO que no pueden ser eliminadas por el usuario.

Qué NO implica:

No todas son espionaje. Muchas son herramientas de seguridad, SSO o DLP legítimas. El problema es la falta de transparencia sobre qué datos recopilan.

Riesgo técnico:

Las extensiones forzadas tienen acceso completo al navegador: contenido de páginas, formularios, contraseñas introducidas, historial y cookies. Algunas pueden interceptar o modificar el tráfico web.

Riesgo jurídico:

Las extensiones con permisos amplios instaladas sin conocimiento explícito del trabajador pueden vulnerar LOPDGDD art. 87. Requieren información previa sobre su función y datos que recopilan.

#27 — Políticas corporativas en Google Chrome (3 activas)

ORANGE

Skill: browser_audit | Categoría: browser_policies | Timestamp: 2026-05-31T07:47:35.155439

Qué es:

Políticas GPO que controlan el comportamiento del navegador: qué puede hacer el usuario, qué datos se envían y cómo se gestiona la sesión.

Qué NO implica:

Las políticas de navegador son gestión corporativa estándar. El problema es cuándo incluyen reporting de actividad sin transparencia.

Riesgo técnico:

CloudReportingEnabled envía datos de actividad del navegador al administrador corporativo. El bloqueo del modo incógnito impide al trabajador tener sesiones de navegación privadas. BrowserSignin forzado vincula la actividad al perfil corporativo y la sincroniza.

Riesgo jurídico:

CloudReportingEnabled sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

#28 — Políticas corporativas en Microsoft Edge (4 activas)

ORANGE

Skill: browser_audit | Categoría: browser_policies | Timestamp: 2026-05-31T07:47:35.175715

Qué es:

Políticas GPO que controlan el comportamiento del navegador: qué puede hacer el usuario, qué datos se envían y cómo se gestiona la sesión.

Qué NO implica:

Las políticas de navegador son gestión corporativa estándar. El problema es cuándo incluyen reporting de actividad sin transparencia.

Riesgo técnico:

CloudReportingEnabled envía datos de actividad del navegador al administrador corporativo. El bloqueo del modo incógnito impide al trabajador tener sesiones de navegación privadas. BrowserSignin forzado vincula la actividad al perfil corporativo y la sincroniza.

Riesgo jurídico:

CloudReportingEnabled sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

#29 — Políticas corporativas en Mozilla Firefox (1 activas)

ORANGE

Skill: browser_audit | Categoría: browser_policies | Timestamp: 2026-05-31T07:47:35.188736

Qué es:

Políticas GPO que controlan el comportamiento del navegador: qué puede hacer el usuario, qué datos se envían y cómo se gestiona la sesión.

Qué NO implica:

Las políticas de navegador son gestión corporativa estándar. El problema es cuándo incluyen reporting de actividad sin transparencia.

Riesgo técnico:

CloudReportingEnabled envía datos de actividad del navegador al administrador corporativo. El bloqueo del modo incógnito impide al trabajador tener sesiones de navegación privadas. BrowserSignin forzado vincula la actividad al perfil corporativo y la sincroniza.

Riesgo jurídico:

CloudReportingEnabled sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

#30 — Configuraciones de seguridad ausentes (8 de 14)

RED

Skill: hardening_audit | Categoría: hardening_missing | Timestamp: 2026-05-31T07:48:23.349617

Qué es:

Configuraciones de seguridad de Windows que deberían estar activas en un equipo corporativo gestionado pero no lo están.

Qué NO implica:

No implica que el equipo esté comprometido. Indica que las protecciones estándar no se han aplicado, lo que aumenta la superficie de riesgo.

Riesgo técnico:

Las configuraciones de seguridad ausentes reducen la protección del sistema y pueden facilitar la instalación o ejecución de software no autorizado, incluyendo herramientas de vigilancia.

Riesgo jurídico:

El empleador tiene obligación de garantizar la seguridad de los equipos corporativos bajo RGPD art. 32. La ausencia de medidas técnicas básicas puede constituir incumplimiento de esta obligación.

#31 — AUSENTE: BitLocker — Cifrado de disco

RED

Skill: hardening_audit | Categoría: hardening_encryption | Timestamp: 2026-05-31T07:48:23.376503

Qué es:

BitLocker — Cifrado de disco

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

Los datos del disco son accesibles sin autenticación si se extrae el disco o se arranca desde medio externo.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#32 — AUSENTE: Secure Boot — Arranque seguro

ORANGE

Skill: hardening_audit | Categoría: hardening_boot | Timestamp: 2026-05-31T07:48:23.394979

Qué es:

Secure Boot — Arranque seguro

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

El sistema puede ser comprometido a nivel de firmware sin que ninguna herramienta de seguridad lo detecte.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#33 — AUSENTE: Windows Firewall — Cortafuegos

ORANGE

Skill: hardening_audit | Categoría: hardening_network | Timestamp: 2026-05-31T07:48:23.409430

Qué es:

Windows Firewall — Cortafuegos

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

El equipo está expuesto a conexiones entrantes desde la red local sin filtrado.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#34 — AUSENTE: Windows Defender — Protección en tiempo real

ORANGE

Skill: hardening_audit | Categoría: hardening_antimalware | Timestamp: 2026-05-31T07:48:23.427647

Qué es:

Windows Defender — Protección en tiempo real

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

Malware puede ejecutarse libremente sin detección hasta el próximo análisis manual.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#35 — Cuentas locales detectadas (8 total, 2 sospechosas)

ORANGE

Skill: identity_audit | Categoría: identity_local_accounts | Timestamp: 2026-05-31T07:48:27.890570

Qué es:

Cuentas de usuario locales creadas en el equipo, distintas de las cuentas de dominio corporativo.

Qué NO implica:

Las cuentas de sistema (DefaultAccount, WDAGUtilityAccount) son normales en Windows. El riesgo está en cuentas habilitadas no documentadas.

Riesgo técnico:

Cuentas locales con contraseña que no expira o nunca usadas pueden ser puertas traseras para acceso remoto no autorizado al equipo.

Riesgo jurídico:

Cuentas de servicio o soporte no documentadas pueden permitir acceso al equipo del trabajador sin su conocimiento. Bajo LOPDGDD art. 87 el trabajador tiene derecho a saber quién puede acceder a su dispositivo.

#36 — Grupo Administradores: 4 miembros

ORANGE

Skill: identity_audit | Categoría: identity_admin_group | Timestamp: 2026-05-31T07:48:37.870084

Qué es:

Lista de cuentas con privilegios de administrador local en el equipo del trabajador.

Qué NO implica:

Tener administradores corporativos en el equipo es normal en entornos gestionados. El problema es la falta de transparencia sobre quién tiene acceso y con qué finalidad.

Riesgo técnico:

Los administradores locales tienen acceso completo al equipo: pueden leer cualquier archivo, instalar software, acceder a credenciales y monitorizar toda la actividad.

Riesgo jurídico:

El trabajador tiene derecho a saber qué cuentas tienen acceso administrativo a su equipo. Un número elevado de administradores aumenta el riesgo de acceso no autorizado. LOPDGDD art. 87 y RGPD art. 32.

#37 — Acceso remoto habilitado

ORANGE

Skill: identity_audit | Categoría: identity_remote_access | Timestamp: 2026-05-31T07:48:48.397125

Qué es:

Protocolo de escritorio remoto que permite a terceros ver y controlar el equipo a través de la red.

Qué NO implica:

RDP habilitado es normal en entornos corporativos para soporte técnico. El problema es el acceso sin notificación ni consentimiento del trabajador.

Riesgo técnico:

Con RDP habilitado, cualquier administrador puede conectarse remotamente al escritorio del trabajador y ver o controlar todo. Una conexión RDP activa significa que alguien puede estar viendo el escritorio ahora mismo.

Riesgo jurídico:

El acceso remoto al escritorio sin notificación al trabajador puede constituir vigilancia encubierta bajo LOPDGDD art. 87. Una conexión RDP activa no consentida podría vulnerar adicionalmente el art. 197 del Código Penal.

#38 — Credenciales almacenadas en Windows Credential Manager (44)

ORANGE

Skill: identity_audit | Categoría: identity_stored_credentials | Timestamp: 2026-05-31T07:48:48.571276

Qué es:

Almacén seguro de Windows donde se guardan credenciales para acceso automático a recursos de red, RDP y otros servicios.

Qué NO implica:

No es un keylogger. Son credenciales que el usuario guardó voluntariamente para no introducirlas cada vez.

Riesgo técnico:

Las credenciales almacenadas en Windows Credential Manager están cifradas con la clave del perfil de usuario. Un proceso con privilegios de administrador puede extraerlas usando herramientas estándar.

Riesgo jurídico:

Las credenciales almacenadas pueden incluir contraseñas de sistemas personales del trabajador. Su acceso no autorizado vulnera LOPDGDD y puede constituir delito bajo CP art. 197.

#39 — Servicios con cuentas de usuario específicas (8)

YELLOW

Skill: identity_audit | Categoría: identity_service_accounts | Timestamp: 2026-05-31T07:48:48.807786

Qué es:

Servicios de Windows que utilizan cuentas de usuario con credenciales específicas en lugar de las cuentas de sistema estándar.

Qué NO implica:

Es una práctica común en entornos corporativos para servicios que necesitan acceso a recursos de red. No implica actividad maliciosa.

Riesgo técnico:

Servicios que corren bajo cuentas de usuario específicas tienen acceso a los recursos de esa cuenta: archivos, red, credenciales. Si la cuenta tiene privilegios elevados, el servicio también.

Riesgo jurídico:

Servicios de monitorización que corren bajo cuentas de dominio pueden acceder a recursos corporativos con privilegios del usuario. Relevante para determinar el alcance real de la vigilancia.

#40 — Procesos de monitorización con privilegios de sistema (1)

YELLOW

Skill: identity_audit | Categoría: identity_privileged_monitoring | Timestamp: 2026-05-31T07:49:00.276008

Qué es:

Servicios de seguridad que operan con la cuenta SYSTEM de Windows, necesaria para proteger el sistema a nivel de kernel.

Qué NO implica:

Es normal que los agentes EDR/AV corran como SYSTEM. Es un requisito técnico para su función de seguridad, no indica uso indebido.

Riesgo técnico:

Los procesos de SISTEMA tienen acceso sin restricciones a todos los archivos, memoria, red y configuración del equipo. Es el contexto de mayor privilegio posible.

Riesgo jurídico:

Agentes corporativos con privilegios de SISTEMA tienen capacidad técnica para acceder a cualquier dato del trabajador. Su alcance real depende de su configuración, no de sus privilegios técnicos.

#41 — Perfiles de cuentas — 2 con alertas (1 alto riesgo)

ORANGE

Skill: identity_audit | Categoría: identity_account_profiles | Timestamp: 2026-05-31T07:50:30.373851

Qué es:

Análisis de cada cuenta de usuario del sistema: qué es, qué hace, cuándo fue usada por última vez y por qué puede ser relevante.

Qué NO implica:

No todas las cuentas con alertas son maliciosas. Muchas son cuentas de servicio legítimas. El perfil ayuda a identificar cuáles merecen justificación documentada.

Riesgo técnico:

Cuentas con privilegios elevados, contraseña permanente o nunca usadas pueden ser vectores de acceso no autorizado al equipo.

Riesgo jurídico:

El trabajador tiene derecho a conocer qué cuentas tienen acceso a su dispositivo y con qué finalidad. LOPDGDD art. 87 y RGPD art. 32.

#42 — Cuenta: EMEAL-IT — 2 alertas

RED

Skill: identity_audit | Categoría: identity_suspicious_account | Timestamp: 2026-05-31T07:50:30.394222

Qué es:

Cuenta 'EMEAL-IT' detectada con: grupos=['USERS', 'Administradores', 'IIS_IUSRS', 'Usuarios de escritorio remoto', 'Usuarios del registro de rendimiento'], servicios=0, último acceso=/Date(1723032530209)/.

Qué NO implica:

Puede ser una cuenta de servicio corporativo legítima. La alerta indica que merece justificación documentada por parte del empleador.

Riesgo técnico:

■■ En grupos de alto privilegio: administradores, usuarios de escritorio remoto ■■ Cuenta local habilitada — no es cuenta de dominio

Riesgo jurídico:

Esta cuenta puede tener acceso al equipo del trabajador. Su presencia sin documentación puede vulnerar LOPDGDD art. 87.

#43 — .gitconfig global modificado hace menos de 7 días

YELLOW

Skill: git_identity_audit | Categoría: gitconfig_recently_modified | Timestamp: 2026-05-31T07:50:31.623610

Qué es:

Metadato de sistema de ficheros del archivo .gitconfig.

Qué NO implica:

No es evidencia definitiva de intrusión; puede ser un cambio legítimo del propio usuario.

Riesgo técnico:

Cambio reciente de configuración Git global.

Riesgo jurídico:

Si el cambio fue realizado por un proceso automatizado o por herramientas corporativas, el usuario puede haber perdido el control sobre su identidad de firma.

#44 — Configuración SSH personalizada detectada

GREEN

Skill: git_identity_audit | Categoría: ssh_config_present | Timestamp: 2026-05-31T07:50:31.645335

Qué es:

Archivo de configuración SSH que define alias de host, usuarios y claves privadas para conexiones remotas.

Qué NO implica:

No es por sí solo evidencia de acceso no autorizado.

Riesgo técnico:

Las claves SSH presentes permiten autenticación remota sin contraseña a los hosts definidos. Si alguna entrada fue añadida por un proceso ajeno al usuario, podría facilitar acceso no autorizado a servidores.

Riesgo jurídico:

Si la clave SSH es corporativa y da acceso a servidores de la empresa desde un dispositivo personal o no gestionado, puede incumplir las políticas de seguridad del empleador y generar responsabilidades.

#45 — Historial completo de dispositivos USB (6 registros)

GREEN

Skill: usb_audit | Categoría: usb_full_history | Timestamp: 2026-05-31T07:50:47.710548

Qué es:

Registro completo de todos los tipos de dispositivos USB conectados: almacenamiento, HID (teclados/ratones), red, audio, etc.

Qué NO implica:

No incluye contenido de los dispositivos ni archivos transferidos.

Riesgo técnico:

Información de inventario. Útil como referencia forense para identificar dispositivos no autorizados.

Riesgo jurídico:

La información de historial USB es datos técnicos del dispositivo. Su acceso por el empleador puede requerir base legal bajo RGPD.

#46 — Dispositivos USB actualmente conectados (8)

GREEN

Skill: usb_audit | Categoría: usb_connected_now | Timestamp: 2026-05-31T07:51:01.935683

Qué es:

Dispositivos USB reconocidos por Windows como activos en el momento de la auditoría.

Qué NO implica:

No incluye dispositivos desconectados previamente, solo los presentes en el momento actual.

Riesgo técnico:

Inventario de dispositivos activos. Útil para detectar dispositivos de captura de red, grabación o almacenamiento activos.

Riesgo jurídico:

Bajo si son periféricos estándar. Mayor si incluye dispositivos de captura o almacenamiento no autorizados.

#47 — Políticas de restricción de USB/almacenamiento extraíble (1)

YELLOW

Skill: usb_audit | Categoría: usb_dlp_policies | Timestamp: 2026-05-31T07:51:01.955902

Qué es:

Políticas de Windows o GPO corporativas que controlan el acceso a dispositivos de almacenamiento USB y extraíble.

Qué NO implica:

No toda restricción de USB es ilegítima. Es una medida de seguridad estándar en entornos corporativos para prevenir DLP.

Riesgo técnico:

Las políticas DLP de USB limitan la capacidad del trabajador de copiar información. Si son monitorizadas, la empresa puede tener registro de intentos de uso de USB.

Riesgo jurídico:

Las restricciones de USB son medidas DLP legítimas si se informan. Sin embargo, si los intentos de uso se registran y analizan sin base legal, pueden vulnerar LOPDGDD art. 87.

#48 — Add-ins de Outlook detectados (6, 0 con indicadores de monitorización)

YELLOW

Skill: email_audit | Categoría: email_outlook_addins | Timestamp: 2026-05-31T07:51:08.199524

Qué es:

Complementos instalados en Microsoft Outlook que amplían sus funcionalidades. Pueden ser instalados por el usuario o forzados por políticas corporativas.

Qué NO implica:

No todo add-in es vigilancia. Herramientas de firma digital, cifrado, calendarios y productividad también son add-ins legítimos.

Riesgo técnico:

Los add-ins de Outlook se ejecutan dentro del cliente de email y pueden leer, copiar y enviar cualquier elemento del buzón. Los add-ins corporativos forzados pueden enviar copias de emails a sistemas de archivado o supervisión.

Riesgo jurídico:

Add-ins que copian o analizan el contenido del buzón sin información previa al trabajador pueden vulnerar LOPDGDD art. 87 y el secreto de las comunicaciones. Requieren base legal explícita.

#49 — Perfiles de Outlook configurados (1)

GREEN

Skill: email_audit | Categoría: email_outlook_profiles | Timestamp: 2026-05-31T07:51:08.222715

Qué es:

Perfiles de configuración de Microsoft Outlook que agrupan cuentas de email y sus ajustes de conexión.

Qué NO implica:

No contiene el contenido de los emails, solo la configuración de conexión y preferencias del cliente.

Riesgo técnico:

Inventario de perfiles. Múltiples perfiles pueden indicar acceso a cuentas corporativas adicionales no conocidas.

Riesgo jurídico:

Bajo. Es información estructural de configuración. El empleador puede tener acceso a las cuentas Exchange configuradas.

#50 — Apps corporativas con telemetría detectadas (3)

YELLOW

Skill: third_party_apps_audit | Categoría: third_party_apps_installed | Timestamp: 2026-05-31T07:51:22.766959

Qué es:

Aplicaciones de productividad y colaboración corporativas que incluyen funcionalidades de control y telemetría accesibles por administradores de empresa.

Qué NO implica:

La telemetría de diagnóstico estándar (errores, rendimiento) es diferente de las funciones de supervisión de empleados.

Riesgo técnico:

Estas aplicaciones envían telemetría de uso a sus proveedores y pueden tener funciones de control corporativo (exportación de mensajes, grabación de reuniones, estadísticas de actividad) accesibles para administradores de empresa.

Riesgo jurídico:

El uso de funciones de supervisión en estas plataformas (exportación de chats, compliance, Communication Compliance) sin información previa puede vulnerar LOPDGDD art. 87 y ET art. 20bis.

#51 — Políticas corporativas GPO de apps de terceros (2 apps)

ORANGE

Skill: third_party_apps_audit | Categoría: third_party_apps_policies | Timestamp: 2026-05-31T07:51:22.786824

Qué es:

Configuraciones del registro aplicadas por GPO corporativa que controlan el comportamiento de apps como Teams, Zoom, Chrome o VSCode.

Qué NO implica:

No todas las políticas de apps implican supervisión. Muchas son de seguridad: forzar login corporativo, deshabilitar funciones no autorizadas.

Riesgo técnico:

Las políticas GPO de estas apps pueden forzar: telemetría activa, desactivar cifrado E2E, forzar inicio de sesión corporativo, habilitar grabación automática o bloquear ajustes de privacidad.

Riesgo jurídico:

Políticas que activan funciones de supervisión sin informar al trabajador pueden vulnerar LOPDGDD art. 87 y RGPD art. 13. La desactivación forzada de cifrado E2E es especialmente sensible.

#52 — Extensiones de VSCode instaladas (15, 0 con indicadores de telemetría)

GREEN

Skill: third_party_apps_audit | Categoría: vscode_extensions | Timestamp: 2026-05-31T07:51:22.823072

Qué es:

Complementos del editor de código que amplían sus funcionalidades. Pueden ser instalados por el usuario o forzados por políticas.

Qué NO implica:

La mayoría de extensiones son herramientas de productividad legítimas: linting, autocompletado, control de versiones.

Riesgo técnico:

Las extensiones de VSCode se ejecutan con los permisos del usuario y pueden leer archivos, ejecutar comandos y comunicarse con servidores externos. Extensiones de productivity/time tracking pueden monitorizar el tiempo de desarrollo.

Riesgo jurídico:

Extensiones de telemetría de código o time tracking instaladas corporativamente sin información previa pueden vulnerar LOPDGDD art. 87 si monitorizan la actividad del desarrollador.

#53 — Capacidades de logging de actividad activas (1)

YELLOW

Skill: user_behavior_audit | Categoría: behavior_logging_capabilities | Timestamp: 2026-05-31T07:51:44.113299

Qué es:

Funciones de auditoría avanzada de Windows que registran y pueden centralizar la actividad del equipo.

Qué NO implica:

Estas capacidades son herramientas de seguridad estándar. No implican análisis de comportamiento por sí solas.

Riesgo técnico:

Windows Event Forwarding envía todos los logs de seguridad a un servidor central corporativo en tiempo real. PowerShell Transcription guarda literalmente todo lo que escribe el usuario en PowerShell.

Riesgo jurídico:

La centralización de logs de actividad para análisis de comportamiento puede requerir DPIA bajo RGPD art. 35 si se usa para perfilar o evaluar al trabajador.

#54 — Software DLP del empleador activo (5 instalado, 0 en ejecución)

ORANGE

Skill: data_exfiltration_audit | Categoría: exfiltration_dlp_monitoring | Timestamp: 2026-05-31T07:52:06.832410

Qué es:

Software de prevención de pérdida de datos que controla qué información puede salir del equipo corporativo y cómo.

Qué NO implica:

El DLP es una herramienta de seguridad corporativa estándar. No está diseñado para vigilar al empleado sino para proteger la información de la empresa.

Riesgo técnico:

El DLP corporativo puede: inspeccionar el contenido de archivos antes de transferirlos, bloquear transferencias no autorizadas, registrar intentos de exfiltración, inspeccionar tráfico cifrado y enviar alertas al equipo de seguridad.

Riesgo jurídico:

El DLP que inspecciona el contenido de archivos personales del trabajador puede vulnerar el secreto de las comunicaciones y LOPDGDD art. 87. Requiere información previa del alcance.

#55 — Archivos grandes en Downloads/Desktop (2 > 50 MB)

ORANGE

Skill: data_exfiltration_audit | Categoría: exfiltration_large_files | Timestamp: 2026-05-31T07:52:06.851305

Qué es:

Archivos de gran tamaño presentes en carpetas de acceso frecuente del usuario. Pueden ser documentos de trabajo, instaladores o archivos personales.

Qué NO implica:

La presencia de archivos grandes no implica exfiltración. Pueden ser instaladores, backups o proyectos legítimos.

Riesgo técnico:

Archivos comprimidos grandes en Downloads pueden ser preparativos para exfiltración de datos corporativos. Son un indicador forense de actividad de insider.

Riesgo jurídico:

Si la empresa monitoriza el contenido de estas carpetas sin informar, puede vulnerar LOPDGDD art. 87. Desde el punto de vista corporativo, pueden violar DLP.

#56 — Herramientas CLI de nube instaladas (1, 0 con credenciales)

YELLOW

Skill: data_exfiltration_audit | Categoría: exfiltration_cloud_cli | Timestamp: 2026-05-31T07:52:06.868403

Qué es:

Interfaces de línea de comandos para interactuar con servicios de almacenamiento en nube de AWS, Azure, GCP o cualquier proveedor compatible con rclone.

Qué NO implica:

Son herramientas de trabajo legítimas para DevOps y administración. Su presencia no implica exfiltración de datos.

Riesgo técnico:

Herramientas como rclone pueden transferir terabytes de datos a cualquier proveedor de nube con una sola línea de comandos. Si tienen credenciales preconfiguradas, el riesgo es mayor.

Riesgo jurídico:

Desde el punto de vista del trabajador, su uso puede violar políticas de DLP corporativas. Desde el empleador, si se monitoriza el uso de estas herramientas, requiere base legal.

#57 — Playbook de respuesta al trabajador — Urgencia: INMEDIATA (< 24 horas)

RED

Skill: incident_response | Categoría: incident_response_playbook | Timestamp: 2026-05-31T07:52:06.885549

Qué es:

Guía de acción paso a paso para el trabajador, adaptada específicamente a los hallazgos de esta auditoría.

Qué NO implica:

No es asesoramiento jurídico profesional. Para casos graves, consultar con abogado laboralista o sindicato.

Riesgo técnico:

Este playbook sintetiza los hallazgos técnicos de todos los skills de auditoría ejecutados y los traduce en pasos de acción concretos para el trabajador.

Riesgo jurídico:

Las recomendaciones están basadas en RGPD, LOPDGDD, ET art. 20bis y la doctrina Barbulescu II del TEDH. No sustituyen al asesoramiento jurídico profesional.

#58 — Checklist de preservación de evidencia digital

YELLOW

Skill: incident_response | Categoría: incident_response_evidence | Timestamp: 2026-05-31T07:52:06.911260

Qué es:

Guía paso a paso para preservar este informe como evidencia digital con valor legal.

Qué NO implica:

No garantiza la admisibilidad judicial sin peritaje técnico. Para procedimientos judiciales, contactar con perito informático.

Riesgo técnico:

La evidencia digital tiene valor probatorio solo si se preserva correctamente con cadena de custodia documentada.

Riesgo jurídico:

La evidencia correctamente preservada puede ser aceptada en procedimientos ante la AEPD, Inspección de Trabajo o Juzgado de lo Social.

#59 — Guía de derechos y canales de denuncia (31 hallazgos de riesgo alto/muy alto)

YELLOW

Skill: incident_response | Categoría: incident_response_rights | Timestamp: 2026-05-31T07:52:06.930013

Qué es:

Resumen de los derechos reconocidos en RGPD, LOPDGDD y ET aplicables a la situación detectada en esta auditoría.

Qué NO implica:

No es asesoramiento jurídico profesional. Para casos específicos, consultar con abogado laboralista.

Riesgo técnico:

Los hallazgos técnicos de alto riesgo tienen implicaciones legales que el trabajador puede defender ejerciendo sus derechos.

Riesgo jurídico:

El no ejercer estos derechos no implica consentimiento. La prescripción de las infracciones RGPD es de 3 años. Infracciones graves: hasta 20 millones € o 4% facturación global.

#60 — Event Viewer audit parcial: logs no accesibles (2/4)

YELLOW

Skill: event_viewer_audit | Categoría: event_viewer_collection_status | Timestamp: 2026-05-31T07:52:27.120503

Qué es:

Hallazgo de estado del escaneo de logs (cobertura, acceso y volumen de eventos evaluados).

Qué NO implica:

No es prueba de intrusión por sí sola; es un resumen técnico de la ejecución del skill.

Riesgo técnico:

Resumen de cobertura del scanner de Event Viewer, útil para entender qué logs se pudieron inspeccionar y qué volumen se procesó.

Riesgo jurídico:

La falta de acceso puede limitar la cobertura de evidencia forense en el informe.

Evaluación Legal

Modo de recomendaciones: completo. Filtros por categoría: —. Filtros por riesgo: —.

Telemetría completa de Windows activa

HIGH

Windows en nivel de telemetría completo envía datos de actividad, contenido de documentos y uso de aplicaciones a Microsoft en EEUU. Transferencia internacional sin control explícito del trabajador. El empleador como responsable del tratamiento debe garantizar una base legal adecuada bajo RGPD cap. V.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar al DPO la base legal de la telemetría de Windows.
- Verificar si existe DPA entre la empresa y Microsoft.
- Solicitar que IT aplique política GPO de telemetría mínima.
- Exigir registro de actividades de tratamiento que incluya esta transferencia.

Servicio DiagTrack — telemetría continua activa

HIGH

DiagTrack recopila y envía datos de actividad continuamente. En equipos corporativos el empleador es corresponsable del tratamiento bajo RGPD art. 26. No haberlo desactivado por política es una omisión relevante.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar a IT que deshabilite DiagTrack via GPO.
- Verificar que la empresa tiene DPA vigente con Microsoft.
- Documentar el estado actual como evidencia.
- Solicitar el registro de actividades de tratamiento.

Logging centralizado de actividad del equipo activo (WEF, PS Transcription)

HIGH

Windows Event Forwarding y PowerShell Transcription permiten centralizar en tiempo real toda la actividad del equipo. El análisis de este volumen de datos puede constituir un perfilado del trabajador que requiere DPIA bajo RGPD art. 35.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 35 — Evaluación de impacto (DPIA):** Cuando el tratamiento entrañe un alto riesgo para los derechos y libertades de las personas, el responsable debe realizar una evaluación de impacto relativa a la protección de datos.

Recomendaciones:

- Solicitar al DPO si los logs se analizan para evaluar empleados.
- Verificar el período de retención de los logs centralizados.
- Exigir que se informe sobre el uso de los datos recopilados.
- Solicitar la evaluación de impacto (DPIA) si existe.

Cifrado de disco no activo — datos en claro

HIGH

Sin BitLocker activo, en caso de pérdida o robo del equipo todos los datos del trabajador son accesibles sin autenticación. El empleador incumple RGPD art. 32 al no aplicar cifrado en equipos corporativos.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar a IT la activación inmediata de BitLocker.
 - Documentar la ausencia como riesgo de seguridad.
 - Notificar al DPO como posible brecha de seguridad latente.
-

Carpetas del sistema redirigidas a nube corporativa

HIGH

Las carpetas principales de Windows apuntan a OneDrive/SharePoint. Todo lo guardado es inmediatamente accesible por el empleador a través de Microsoft 365.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Documentar qué carpetas están redirigidas.
- Solicitar política de acceso a datos del empleador.
- Crear carpetas locales fuera de OneDrive para uso personal.
- Consultar con asesor laboral sobre el alcance del acceso.

Add-ins de Outlook con acceso al buzón corporativo

HIGH

Los add-ins de Outlook tienen acceso completo a emails, contactos y calendarios. Los add-ins corporativos forzados pueden enviar copias de emails a sistemas de supervisión. Requieren información previa bajo LOPDGDD art. 87.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **TEDH — Doctrina Barbulescu II (2017):** El Tribunal Europeo de Derechos Humanos estableció que la monitorización de comunicaciones laborales debe ser proporcional, limitada en alcance, con base legal, finalidad legítima e informada previamente al trabajador.

Recomendaciones:

- Solicitar al empleador listado de add-ins forzados y su función.
 - Verificar si los add-ins envían datos a sistemas de archivado.
 - Consultar con el DPO qué datos de email se tratan.
 - No usar el email corporativo para comunicaciones privadas.
-

Acceso remoto habilitado al equipo del trabajador

HIGH

RDP habilitado permite acceso completo al escritorio sin que el trabajador lo sepa. Una conexión activa sin notificación puede constituir vigilancia encubierta y vulnerar CP art. 197.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.
- **TEDH — Doctrina Barbulescu II (2017):** El Tribunal Europeo de Derechos Humanos estableció que la monitorización de comunicaciones laborales debe ser proporcional, limitada en alcance, con base legal, finalidad legítima e informada previamente al trabajador.

Recomendaciones:

- Solicitar al empleador política de acceso remoto documentada.
- Exigir notificación previa antes de cualquier acceso remoto.
- Verificar si existe registro de accesos remotos realizados.
- Consultar con asesor laboral si hay accesos no comunicados.

Software DLP corporativo monitorizando transferencias de datos

MEDIUM-HIGH

El DLP corporativo puede inspeccionar el contenido de archivos y comunicaciones del trabajador. La AEPD exige informar previamente sobre el alcance de la inspección de contenidos, especialmente si afecta a archivos personales del trabajador.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **AEPD — Guía de Protección de Datos en Relaciones Laborales:** La AEPD establece que el control laboral mediante tecnología debe cumplir proporcionalidad, necesidad y transparencia. El trabajador debe ser informado con carácter previo.

Recomendaciones:

- Solicitar al DPO la política DLP y qué datos inspecciona.
 - Verificar si el DLP inspecciona contenido personal.
 - No almacenar datos personales en el equipo corporativo.
 - Consultar con asesor laboral sobre el alcance del DLP.
-

Políticas corporativas aplicadas a apps de terceros (Teams, Zoom, Chrome...)

MEDIUM-HIGH

Las políticas GPO sobre apps de terceros pueden forzar telemetría, desactivar cifrado E2E o habilitar supervisión corporativa. El trabajador debe ser informado de qué funciones de control están activas en cada aplicación.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **TEDH — Doctrina Barbulescu II (2017):** El Tribunal Europeo de Derechos Humanos estableció que la monitorización de comunicaciones laborales debe ser proporcional, limitada en alcance, con base legal, finalidad legítima e informada previamente al trabajador.

Recomendaciones:

- Solicitar al DPO listado de políticas activas sobre apps de terceros.
- Verificar si hay funciones de compliance o supervisión activas.
- Consultar con IT qué datos se envían desde cada aplicación.

Políticas GPO de OneDrive forzando sincronización

MEDIUM-HIGH

KFMBlockOptOut impide que el trabajador desactive la sincronización de sus carpetas principales. El trabajador no puede controlar qué datos van a la nube corporativa.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Solicitar al empleador información sobre las políticas GPO.
- Verificar qué datos son accesibles por el admin de M365.
- Documentar la imposibilidad de desactivar la sincronización.

Inspección de tráfico HTTPS sin información acreditada

MEDIUM-HIGH

La inspección SSL permite al empleador leer contenido de comunicaciones cifradas. La doctrina Barbulescu II exige informar previamente al trabajador del alcance.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **TEDH — Doctrina Barbulescu II (2017):** El Tribunal Europeo de Derechos Humanos estableció que la monitorización de comunicaciones laborales debe ser proporcional, limitada en alcance, con base legal, finalidad legítima e informada previamente al trabajador.

Recomendaciones:

- Verificar si la empresa ha informado por escrito sobre la inspección de tráfico.
- Evitar uso de cuentas personales en dispositivos corporativos.
- Solicitar la política de uso aceptable (AUP) de la empresa.

Extensiones forzadas con acceso completo al navegador

MEDIUM-HIGH

Extensiones GPO con permisos amplios pueden interceptar formularios, contraseñas y contenido web. Requieren información previa al trabajador sobre qué datos recopilan.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar al empleador listado de extensiones forzadas y su función.
- Verificar los permisos de cada extensión en `chrome://extensions`.
- No introducir datos personales en formularios web en equipos corporativos.

Experiencias conectadas de Office enviando contenido a Microsoft

MEDIUM-HIGH

Office 365 envía contenido de documentos a Microsoft para funciones de IA: traducción, diseño, sugerencias. Puede incluir datos personales de clientes y empleados sin base legal adecuada o sin conocimiento del trabajador.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar el DPA entre la empresa y Microsoft.
- Verificar qué experiencias conectadas están activas.
- Solicitar DPIA si se procesan datos de categoría especial.
- Desactivar experiencias conectadas no necesarias para el trabajo.

Cuenta específica con características de riesgo

MEDIUM-HIGH

Una cuenta habilitada con privilegios elevados y sin uso documentado puede ser una puerta trasera para acceso no autorizado al equipo del trabajador.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.

Recomendaciones:

- Solicitar justificación específica de esta cuenta al empleador.
- Verificar si aparece en el inventario oficial de cuentas.
- Consultar con asesor laboral si no hay justificación.
- Preservar este informe como evidencia.

Credenciales almacenadas accesibles para administradores

MEDIUM-HIGH

Las credenciales en Windows Credential Manager pueden ser extraídas por administradores. Si incluyen contraseñas personales del trabajador, su acceso no autorizado vulnera LOPDGDD y CP art. 197.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- No guardar contraseñas personales en Windows Credential Manager.
- Usar un gestor de contraseñas personal independiente.
- Revisar qué credenciales están almacenadas con `cmdkey /list`.

Configuraciones de seguridad básicas ausentes

MEDIUM-HIGH

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de protecciones básicas puede constituir incumplimiento y aumenta el riesgo para los datos del trabajador.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar al empleador el plan de hardening de equipos.
- Exigir activación de BitLocker si no está presente.
- Documentar las ausencias como parte del informe forense.
- Presentar al DPO como posible incumplimiento RGPD art. 32.

Acceso al portapapeles del trabajador

MEDIUM-HIGH

El portapapeles puede contener contraseñas, tokens y datos bancarios. Su acceso por software corporativo sin consentimiento puede capturar datos especialmente sensibles bajo RGPD art. 9.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.

Recomendaciones:

- Identificar qué aplicación accede al portapapeles.
- No copiar credenciales ni datos sensibles en equipos corporativos.
- Solicitar al DPO información sobre el tratamiento de estos datos.

Telemetría de Microsoft Office sin política restrictiva

MEDIUM

Office 365 recopila datos de uso, nombres de archivos y en configuración por defecto fragmentos de contenido. Sin política GPO restrictiva aplica la configuración más permisiva por defecto.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar a IT política GPO de privacidad de Office.
- Verificar el nivel de telemetría configurado.
- Comprobar que el DPA con Microsoft está actualizado.

Servicios con cuentas de usuario específicas

MEDIUM

Servicios que corren bajo cuentas de dominio tienen acceso a recursos de red con privilegios de esa cuenta. Si son cuentas de monitorización, su alcance real puede ser mayor del esperado.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar inventario de servicios y cuentas asociadas.
- Verificar que cada servicio tiene justificación documentada.
- Consultar al DPO si algún servicio trata datos del trabajador.

Servicio de sincronización en nube activo

MEDIUM

La sincronización automática puede constituir transferencia internacional de datos personales bajo RGPD cap. V. El empleador debe tener DPA con el proveedor y base legal adecuada.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar al DPO el DPA con cada proveedor de nube activo.
- Verificar qué datos se sincronizan y hacia qué región.
- Solicitar el registro de actividades de tratamiento.

Políticas corporativas de navegador activas

MEDIUM

CloudReportingEnabled envía actividad del navegador al administrador. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Verificar si CloudReporting está activo en `chrome://policy`.
- Solicitar al DPO qué datos de navegación se recopilan.
- No usar el navegador corporativo para asuntos personales.

Políticas corporativas de control de almacenamiento USB

MEDIUM

La empresa tiene activas políticas GPO de control de dispositivos USB. Si estas políticas registran intentos de conexión o uso, se está tratando información del trabajador. Requiere información previa bajo LOPDGDD art. 87 y RGPD art. 13.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar al empleador la política de uso de dispositivos USB.
- Verificar si se registran los intentos de conexión USB.
- Comprobar si el registro es accesible por Recursos Humanos.
- Consultar con el DPO qué datos se conservan y por cuánto tiempo.

Múltiples administradores con acceso completo al equipo

MEDIUM

Un número elevado de administradores locales aumenta el riesgo de acceso no autorizado. El trabajador tiene derecho a saber quién puede acceder a su equipo y con qué finalidad.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar al empleador lista de cuentas con acceso admin.
- Verificar que el número de admins está justificado.
- Exigir registro de auditoría de accesos administrativos.

Herramientas CLI de nube con acceso a credenciales configuradas

MEDIUM

Herramientas CLI de nube (rclone, AWS CLI) con credenciales preconfiguradas en el equipo corporativo pueden usarse para transferir datos masivamente. Su uso puede ser monitorizado por el DLP corporativo.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Verificar que las credenciales de nube son corporativas, no personales.
- Asegurar que el uso de estas herramientas está autorizado.
- Consultar con IT la política de uso de herramientas de nube.

Extensiones de navegador forzadas con acceso a contenido web

MEDIUM

Las extensiones corporativas con acceso completo a páginas web pueden leer formularios, contraseñas y contenido personal.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Identificar qué extensiones están instaladas y su editor.
- Solicitar información sobre su función a IT.
- No usar el navegador corporativo para asuntos personales.

Extensiones de VSCode con indicadores de telemetría de actividad

MEDIUM

Extensiones de time tracking o productividad en VSCode pueden monitorizar el tiempo de trabajo, los proyectos activos y la actividad del desarrollador. Si son instaladas corporativamente sin información, puede vulnerar LOPDGDD art. 87.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Revisar qué extensiones están instaladas y su origen.
- Identificar extensiones de time tracking o productividad.
- Verificar si hay extensiones forzadas por políticas corporativas.

Cuentas locales no documentadas con acceso al equipo

MEDIUM

Cuentas habilitadas con contraseña permanente o nunca usadas pueden ser puertas traseras. El trabajador tiene derecho a saber qué cuentas tienen acceso a su dispositivo.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar al empleador inventario de cuentas locales y su función.
- Verificar si hay cuentas de soporte remoto no documentadas.
- Solicitar que IT deshabilite cuentas no necesarias.

Cuentas con alertas de seguridad sin documentar

MEDIUM

Cuentas habilitadas con privilegios elevados o nunca usadas pueden ser vectores de acceso no autorizado. El trabajador tiene derecho a saber qué cuentas tienen acceso a su dispositivo.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar inventario completo de cuentas y su justificación.
- Exigir que IT deshabilite cuentas no necesarias.
- Documentar este informe como evidencia del estado actual.

Cobertura de Event Viewer y accesibilidad de registros

MEDIUM

El resultado de cobertura del visor de eventos indica si el informe dispone de base forense suficiente o si hay limitaciones de acceso a registros clave.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Si hay logs no accesibles, solicitar ejecución con permisos adecuados.
- Conservar el estado de cobertura como parte de la cadena de evidencia.
- Documentar ventana temporal y alcance para trazabilidad del análisis.

Agentes de monitorización con privilegios de SISTEMA

MEDIUM

Procesos de SISTEMA tienen acceso sin restricciones a todos los datos del equipo. Los agentes EDR con estos privilegios tienen capacidad técnica de acceso total.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Solicitar al DPO qué datos recopilan estos agentes.
- Verificar que existe política de uso de datos del EDR.
- Documentar qué agentes corren como SISTEMA.

Agente EDR/XDR corporativo

LOW

Los EDR son considerados seguridad corporativa estándar y generalmente cumplen el principio de proporcionalidad si están orientados a la detección de amenazas.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Verificar que existe política de seguridad documentada.
- Comprobar que el uso de datos del EDR se limita a finalidades de seguridad.

Integridad del Informe

Este informe incluye un hash SHA-256 de su contenido para verificar que no ha sido modificado desde su generación.

SHA-256 del contenido:

9a03f93ab018ae03e53183c3f8ed6dc490c3b3d974208b692c38fb0f6985eb9a

Para verificar la integridad, recalculé el hash del archivo JSON exportado junto a este informe y compárelo con el valor anterior.